

CyLab St3g0 Challenge Writeup

Challenge Overview

Event: PicoCTF 2022

Challenge Name: St3g0

Category: Forensics

Difficulty: Medium

Points: 300

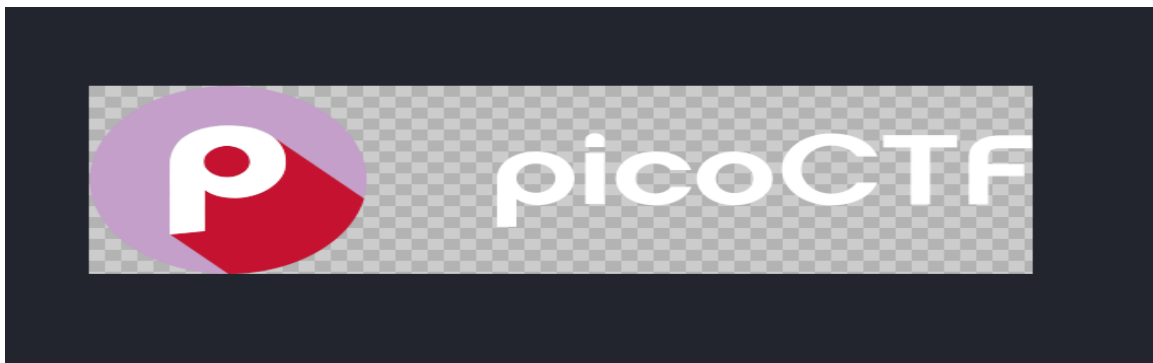
Challenge Description

Download this image (pico.flag.png) and find the flag

Hint: we know the end sequence of the message will be \$t3g0

Step 1: Viewing the Image

Download the pico.flag.png to see what you are working with. Once the image is downloaded all you will see is the picoCTF logo. Nothing suspicious upon first glance.



Step 2: Utilizing Exiftool & XXD

First let's discover what additional information we can uncover about the image using exiftool. Exiftool is an excellent tool for extracting metadata from files to see if there are any mismatches.

```
$ exiftool pico.flag.png
ExifTool Version Number      : 13.55
File Name                    : pico.flag.png
Directory                    : .
File Size                    : 13 kB
File Modification Date/Time   : 2026:07:18 13:45:37-07:00
File Access Date/Time        : 2026:07:18 13:45:51-07:00
File Inode Change Date/Time   : 2026:07:18 13:45:50-07:00
File Permissions              : -rw-rw-r--
File Type                    : PNG
File Type Extension          : png
MIME Type                    : image/png
Image Width                  : 585
Image Height                 : 172
Bit Depth                    : 8
Color Type                   : RGB with Alpha
Compression                  : Deflate/Inflate
Filter                       : Adaptive
Interlace                    : Noninterlaced
Image Size                   : 585x172
Megapixels                   : 0.101
```

The results gathered from exiftool inform me that pico.flag.png is indeed a png and not some other type of extension such as jpeg for example. Let's make sure my thinking is correct by using the xxd command in the terminal. XXD performs a hex dump to inspect raw file data that will confirm if this is indeed a PNG file.

```

$ xxd pico.flag.png
00000000: 8950 4e47 0d0a 1a0a          0d 4948 4452 .PNG... .IHDR
00000010:          0249          ac 0806          6f 9638 .I ... o.8
00000020: 2c          34 4a49 4441 5478 9ced dd79 7c54 , 4JIDATx ... y|T
00000030: e5f5 f8f1 cf99 c906 09bb 280a 2820 a888 .....( ( ..
00000040: b8b2 2810 14d7 bad6 bad0 d61d acfa b5fa ..(.....
00000050: 6b6d ad56 c12a 5641 fbd5 b67e b5b5 2e15 km.V.*VA ... ~...
00000060: d0aa ad68 adda bad6 8ab2 2804 1050 3605 ...h.....( ..P6.
00000070: 1451 10d9 4280 ec33 737e 7fdc 8102 9230 .Q..B..3s~....0
00000080: f7ce bd73 6792 f37e 352f 0bb9 f779 ce24 ...sg..~5/ ...y.$
00000090: 2139 b9cf f39c 2388 20aa 2820 0228 80f3 !9....#. .( .( ..
000000a0: 7f54 846d 04c5 f99f 38ef 1545 14d4 f983 .T.m....8..E....
000000b0: f37e 91e4 fdea 0ce1 fc2d c91b b7bf df79 .~.....~.....y
000000c0: 9726 2fdd 76af f3ff 9dff 3a7f 5615 b647 .6/.v...:..V..G
000000d0: 238a 6c7f ffb6 a014 4dde afe0 44b6 c3fd #.l...M...D...
000000e0: a838 4326 5f9f 33bf 73f3 f6ff 9b7c 8de2 .8C6_.3.s...|..
000000f0: fc61 87f1 1525 f93e 515e 7df0 d3c2 56ad .a...%.>Q^} ...V.
00000100: 371e 204a 374d b03f 12d9 5b55 3a 1d24 7. J7M.?..[U: .$
00000110: aa1d 5429 42a5 18d5 82e4 47a8 0548 b5f3 ..T)B.....G..H..
00000120: f1d1 2d12 2116 51a9 48a0 eb50 36 1b20 ..-!.Q.H..P6 .
00000130: b146 a2b2 4225 6f45 e965 c77c bdd3 c727 .F..B%oE.e.| ... '
00000140: f9f1 745e 8a6e 7fc9 c618 638c c90c d9f3 ..t^.n....c....
00000150: 25cd cbc2 490b 0b36 6cad 3e0c 491c 2e48 %...I..6l.>.I..H
00000160: 5f44 0f47 e90d ec47 b01f af1a 60b9 c282 _D.G...G....` ...
00000170: 8832 5fd1 8f25 2ffa d190 cbfa ad0c 704e .2_..%/. ....pN
00000180: 638c 31c6 3a40 9d27 49ef ff9f fdf6 f168 c.1.4.. 'I.....h
00000190: de60 90c1 4862 302a fd80 a2b0 e3da c12a .`..Hb0*.....*
000001a0: 90f7 41a7 4b42 a7af 6ef5 c5dc e1c3 87c7 ..A.KB..n.....
000001b0: c30e ca18 638c 69ea 9a65 9234 6d62 591f ....c.i...e.4mbY.
000001c0: 553d 0b91 9351 8e07 f2c3 8e29 550a 1b04 U= ...Q.....)U..
000001d0: 7907 e1ed a8d4 bf3a e8f2 41ab c28e c918 y.....: ..A.....
000001e0: 638c 698a 9a4d 92e4 2446 7229 e825 40e7 c.i..M..$Fr).%@.
000001f0: b0e3 f149 02f8 78 5e12 79cf 0fb9 f2e8 ...I.. x^.y.....
00000200: d561 0764 8c31 c634 154d 3a49 9afa e4cc .a.d.1.4.M:I...
00000210: 8388 47ae 44f4 8740 d7b0 e309 581c 988a ..G.D..@...X...
00000220: e884 16b5 d117 fa5d d3af 2aec 808c 31c6 .....] ..* ...1.
00000230: 985c d6e4 92a4 d71e 5c5a d8ba d5c6 f315 .\.....\Z.....
00000240: b90a 389e 26f8 1a53 b009 7886 843e 5e7a ..8.6..S..x..>^z
00000250: e5c0 f961 0763 8c31 c6e4 a226 9340 fcfb ...a.c.1...6.@..
00000260: d1d9 6d8a 0a12 57 37d1 7496 d3fc 301d ..m...W 7.t...0.
00000270: f4ff be2e fee2 45db f06d 8c31 c6a4 2ee7 ....E..m.1...
00000280: 93a4 c913 3ee8 1625 ef97 825e 06b4 0c3b ....>.%...^...;
00000290: 9e2c b644 44ef 2faa 8d3e d5ef 9a7e f561 ., .DD./ ..> ...~.a
000002a0: 0763 8c31 c664 bb9c 4d92 263f 3ea3 4b5e .c.1.d..M.6?>.K^
000002b0: 3472 13c2 3540 61d8 f1e4 0efd 0289 8c8b 4r...5@a.....
000002c0: add8 3a7e d898 61b1 b0a3 31c6 1863 b255 ..:~..a...1..c.U
000002d0: ce25 49ef fff9 fdf6 b168 deaf 04fe 87ec .%I.....h.....
000002e0: aa67 946b 3e51 95db 868e ecff 42d8 8118 .g.k>Q.....B...
000002f0: 638c 31d9 2867 92a4 c963 26e7 e575 2b19 c.1.(g...c6..u+.
00000300: 89ea dd40 c7b0 e369 3a74 a6a0 370c 1971 ...@...i:t..7..q
00000310: ec8c b023 31c6 1863 b249 4e24 4953 2696 ...#1..c.IN$IS6.
00000320: 9d24 0979 08d1 de61 c7d2 4425 4418 9f2f .$.y...a..D%D../
00000330: 7acb c0cb 076e 083b 1863 8c31 261b 6475 z....n.;.c.16.du
00000340: 9234 79c2 dcb6 795a ff1b 84ab c8f2 589b .4y...yZ.....X.
00000350: 888d 88dc 5a7a 45ff c7c2 0ec4 1863 8c09 ....ZzE.....c..
00000360: 5bd6 261e 5327 ccbc 10e4 2160 9fb0 6369 [.6.S'....!`..ci
00000370: 6e04 7935 ae7a edf1 2307 7c19 762c c618 n.y5.z..#.|.v,..
00000380: 634c 58b2 2e49 9af1 f48c d6f5 7591 fb10 cLX..I.....u...
00000390: ae0e 3b96 666e b32a d70d 1d39 e0e9 b003 ..;.fn.*...9....

```

Here we can see that the xxd command has indeed proven we are dealing with a PNG because of its magic numbers. Magic numbers are a specific sequence of bytes located at the beginning of a file that are a unique fingerprint that identifies the file's true format. PNG magic numbers will always be 89 50 4E 47 0D 0A 1A 0A and you can see that those magic numbers are displayed once we ran the xxd command. Now that I know for certain that this is a PNG I can try different techniques to solve this challenge.

Step 3: Steganography Technique

Upon looking back at the challenge name, it hit me that I need to use a steganography technique to solve this challenge. The first steganography tool I could think of was zsteg. Zsteg is a Ruby-based steganography tool designed to detect and extract hidden data within PNG and BMP files making it an excellent tool for this challenge. If you do not have zsteg run the following commands to obtain zsteg: `sudo apt update -> sudo apt install ruby-dev -> sudo gem install zsteg`. Once you have run those commands you will now have zsteg for you to utilize. Run the command below to obtain the flag for the challenge. Flag has been redacted in the screenshot below.

```
$ zsteg pico.flag.png
b1,r,lsb,xy      .. text: "~_B>VG?G@"
b1,abgr,lsb,xy   .. text: "E2A5q4E%uSA"
b2,b,lsb,xy      .. text: "AAPAAQTAAA"
b2,b,msb,xy      .. text: "HWUUUUUU"
b4,r,lsb,xy      .. file: Targa image data (16-273) 65536 x 4097 x 1 +4352 +4369 - 1-bit alpha - right "\021\020\001\001\021\021\001\021\001\021\001"
b4,g,lsb,xy      .. file: 0420 Alliant virtual executable not stripped
b4,b,lsb,xy      .. file: Targa image data - Map 272 x 17 x 16 +257 +272 - 1-bit alpha "\020\001\021\001\021\020\020\001\020\001\020\001"
b4,bgr,lsb,xy    .. file: Targa image data - Map 273 x 272 x 16 +1 +4113 - 1-bit alpha "\020\001\001\001"
b4,rgba,msb,xy   .. file: Applesoft BASIC program data, first line number 8
```

Closing Thought

In conclusion, the St3g0 challenge was fun, not difficult, and required you to use different tools to solve this challenge. The St3g0 challenge showcased digital forensic techniques such as exiftool, xxd, and zsteg; that you will use in real-world applications such as CTF's, blue team operations, etc. What did you think of the challenge? What techniques did you use to solve this challenge?

Securing the digital realm one computer at a time.

Best Regards,

Dylan